

Compare types of cyber security testing

The exact type of testing that an organisation chooses will depend on many things, such as the organisation's business, its size, the experience of its IT department, etc. Here is some information that can help you to decide when to use different types of security testing.

Pros and cons of penetration testing

A pen test is best for when an organisation wants to focus on testing for vulnerabilities in a new system or project, or when it has a particular area of concern. Because of this focus, pen tests are more useful as a way to find specific vulnerabilities, rather than as a way to test how security teams would respond to a real cyber attack.

Pros:

- They can identify a wide range of vulnerabilities.
- They can identify risks from smaller vulnerabilities. Taken on their own, small vulnerabilities may appear less dangerous, but attackers often use these as an entry point. Because pen testers use the same methods as hackers, they can find these points of entry.
- Reports will provide specific advice. Unlike automatically generated reports from automated testing tools, pen testers will write a detailed report that is specific to your needs, including ranking and rating each vulnerability according to the criteria the organisation chooses.

Cons:

- If a pen test is not done right, it can cause damage. Tests that are not done properly can crash servers, expose sensitive data, corrupt crucial production data, or cause other adverse effects associated with mimicking a criminal hack.
- You need to trust the penetration tester. The organisation is relying on the tester not to abuse their skills and knowledge.
- If you don't use realistic test conditions, the results can be misleading. Employees are likely to prepare for a test that they know is going to take place, meaning that the organisation appears to be stronger than it actually is.
- Pen testing is poorly defined. You must make sure the pen tester understands your organisation's needs before they start.

The pros and cons of vulnerability scanning

Vulnerability scanning is often used for checking systems that face the internet, like corporate web servers, virtual private network endpoints and office internet connections. Another common use for vulnerability scanning is as part of the software development lifecycle. However, it isn't helpful when you want to test against human attackers – pen tests are more useful for that.

Pros:

- They can identify vulnerabilities early. Many cyber attacks are automated, using bots to search for and exploit known vulnerabilities. So, by using the same tools, an organisation can discover these weaknesses before the criminals do.
- Regular scans can tell you how effective your security is. If the scans expose a lot of vulnerabilities, that's a sign that your systems or software are severely flawed and need to be rethought.
- Save time and money. Automated scans are easy to conduct and can be repeated often.
- Meet data protection requirements. Regular vulnerability scanning can help organisations demonstrate they are meeting GDPR regulations on identifying vulnerabilities.
- Quickly highlight problems that might have been missed. Vulnerability scans help to tidy up low-level issues at little cost. This is a bonus, because organisations are most often exploited not by advanced, large-scale attacks, but by smaller, easier attacks.

Cons:

- You won't find every vulnerability. Even with the latest technology, there will almost certainly be weaknesses that the scanner won't pick up. This might be because it's newly discovered or because the vulnerability is too complex to be detected by an automated tool.
- False positives – it's not always easy to work out what the results of a vulnerability scan mean. It can sometimes take the help of an expert to filter out false positives.

Pros and cons of red team testing

A red team exercise is used when you want to see, as closely as possible, how real attackers would act against you. It is not a replacement for vulnerability scans and penetration tests, but a high-level test designed for specific situations. It can be as a 'purple team' training exercise – when you have an attacking red team and a defending 'blue' team.

Pros:

- Training – this is a good way to test the ability of an IT team or Security Operations Centre to detect particular types of attacks.
- Useful for large organisations – a red team exercise can help demonstrate the breadth and depth of attacks that a large, high-value organisation faces.
- Builds a picture of how real attackers could work their way through an organisation's infrastructure.

Cons:

- Not useful for finding all vulnerabilities. A red team attacker will only find and exploit the vulnerability needed to achieve their goal. If they can get into your internal network through a poorly configured VPN but could have achieved the same through poor wireless security at your remote offices, you may not discover both issues.
- High cost – a red team exercise requires specialists, who do not come cheap.

Pros and cons of social engineering testing

This type of testing can help you pick up vulnerabilities in areas that are not covered in other types of testing, especially in automated tests.

Pros:

- Prepares for a common type of attack. Social engineering attacks are very common and it is likely that every organisation will face them at some point.
- Helps employees. Training in preventing social engineering attacks will help employees to prevent attacks in their personal life as well as at work.

Cons:

- Focuses only on social engineering attacks. This type of testing cannot be used on its own – it should be combined with vulnerability and/or pen testing.
- Can be out of date. Social engineering attacks change frequently, so organisations will need to redo or update these tests frequently.

Fill in the chart with the pros and cons of each type of test.

	Pros	Cons
Social engineering testing		
Red team testing		
Vulnerability scanning		
Penetration testing		